

Security+ 5.5 · Audits & Assessments

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.5 — Audits & Assessments (2:49)**

· [Vídeo no YouTube ↗](#)

Resumo da Aula: Audit: internal (da empresa) vs external (terceiro — certified, regulator); reasons: verificar se controls funcionam, prover cliente/regulador; compliance monitoring CONTÍNUO (não só anual).

Highlights que a prova cobra

- Internal audit = da própria empresa; external = terceiro
- Compliance monitoring: período-contínuo, NÃO só o anual

Dicas de prova & Cenários Típicos

- 'independent verification by third-party'=external audit

Cenário clássico de exame: 'consultoria externa audita o SGSI'=external audit.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 5.5)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Audits & Assessments) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Estratégias de Tratamento de Risco:**
 - **Mitigação/Redução:** aplicar controles técnicos ou administrativos para diminuir probabilidade ou impacto (ex: instalar EDR).
 - **Transferência/Compartilhamento:** repassar o impacto financeiro para um terceiro (ex: contratar seguro cibernético ou terceirizar para um MSSP).
 - **Aceitação:** reconhecer o risco quando o custo do controle supera o valor do ativo (exige aprovação formal da alta liderança).
 - **Evitação:** cancelar ou não iniciar a atividade arriscada (ex: descontinuar um serviço legado inseguro).
- **Métricas de Risco e Análise Quantitativa:**
 - **SLE (Single Loss Expectancy):** perda financeira estimada para uma única ocorrência do incidente ($\text{Asset Value} \times \text{Exposure Factor}$).
 - **ARO (Annualized Rate of Occurrence):** frequência anual estimada do evento.
 - **ALE (Annualized Loss Expectancy):** custo anualizado total do risco: $\text{ALE} = \text{SLE} \times \text{ARO}$.
- **Métricas de Continuidade de Negócios (BCP / DRP):**
 - **RTO (Recovery Time Objective):** tempo máximo tolerável que o sistema pode ficar inoperante após um desastre.
 - **RPO (Recovery Point Objective):** volume máximo de dados que a organização tolera perder, medido em tempo (ex: se o backup é diário, o RPO é de até 24 horas de transações perdidas).
 - **MTBF (Mean Time Between Failures):** tempo médio em que um equipamento opera sem falhas.
 - **MTTR (Mean Time to Repair):** tempo médio necessário para consertar ou substituir um componente com defeito.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Se a questão disser 'contratar apólice de seguro contra ataques cibernéticos' = **Transferência de Risco** (nunca mitigação).
- RPO define a frequência dos backups; RTO define a velocidade da infraestrutura de restauração e failover.

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. ISO/IEC 27001 é:

- A)** A norma INTERNACIONAL de gestão de segurança da informação (SGSI)
- B)** Uma lei dos EUA
- C)** Um tipo de firewall
- D)** Um scanner de vulnerabilidade

2. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Internal audit = da própria empresa; external = terceiro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Compliance monitoring: período-contínuo, NÃO só o anual'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Compliance monitoring: período-contínuo, NÃO só o anual...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: "independent verification by third-party'=external audit'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'independent verification by third-party'=external audit...

5. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: "consultoria externa audita o SGSI'=external audit.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'consultoria externa audita o SGSI'=external audit....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Internal audit = da própria empresa; external = terceiro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Compliance monitoring: período-contínuo, NÃO só o anual'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Compliance monitoring: período-contínuo, NÃO só o anual...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'independent verification by third-party'=external audit'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'independent verification by third-party'=external audit...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'consultoria externa audita o SGSI'=external audit.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'consultoria externa audita o SGSI'=external audit....

10. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Internal audit = da própria empresa; external = terceiro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — A norma INTERNACIONAL de gestão de segurança da informação (SGSI).

✓ **Por que está certa:** ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR).

✗ **Por que as outras estão erradas:**

- *Uma lei dos EUA:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Um tipo de firewall:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Um scanner de vulnerabilidade:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) C — Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Internal audit = da própria empresa; external = terceiro.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) A — Implementar a solução correspondente: Compliance monitoring: período-contínuo, NÃO só o anual....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Compliance monitoring: período-contínuo, NÃO só o anual.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) D — Implementar a solução correspondente: 'independent verification by third-party'=external audit....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 5.5 (Audits & Assessments): 'independent verification by third-party'=external audit.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'consultoria externa audita o SGSI'=external audit.....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): 'consultoria externa audita o SGSI'=external audit..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Internal audit = da própria empresa; external = terceiro.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: Compliance monitoring: período-contínuo, NÃO só o anual....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Compliance monitoring: período-contínuo, NÃO só o anual.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'independent verification by third-party'=external audit....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): 'independent verification by third-party'=external audit.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'consultoria externa audita o SGSI'=external audit.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): 'consultoria externa audita o SGSI'=external audit..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Internal audit = da própria empresa; external = terceiro.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.